

OPERATION BLACK FORGE — LESSONS LEARNED

STATEMENT

CTF 2 | Daniyal Ahmed — C11/26/EHIT/17331 | 22 September 2026

1. Operational Summary

Operation Black Forge was successfully completed with full root-level compromise of OPFOR-02 (192.168.233.130 — PCLinuxOS Healthcare VM running OpenEMR 4.1.0). The engagement was conducted in a single session on 22 September 2026 within an isolated VirtualBox Host-Only network. Root proof: eaff25eaa9ffc8b62e3dfefb70e83a7b.

The attack chain traversed four stages: SQL injection credential extraction, admin panel PHP shell injection, and SUID PATH hijacking privilege escalation to root.

2. Key Technical Lessons

2.1 Enumeration Quality Determines Attack Surface

The use of both dirb and gobuster was critical. The /openemr/ path — the sole entry point to the attack chain — was discovered through systematic content discovery against a web server showing only a "Coming Soon" page. Without enumeration, the application would have remained invisible. This reinforces the principle that thorough enumeration must precede any exploitation attempt.

2.2 SQL Injection Remains Highly Impactful

The OpenEMR SQL injection vulnerability (EDB-49742) demonstrates that even in 2026, widely-known vulnerability classes continue to exist in production software. The 'u' parameter in validateUser.php accepted unsanitised input and returned the full database. A single injectable parameter was sufficient to compromise the entire application tier.

2.3 Credential Weakness Compounds Vulnerability Chains

The administrator account used a password stored as an unsalted MD5 hash that was cracked immediately from an online service. Without weak credentials, the SQL injection would have yielded only locked hashes. The combination of weak hashing and weak passwords converted a data exposure into a full application compromise.

2.4 Application Admin Panels Can Provide Execution

The OpenEMR file editor was an unexpectedly powerful attack primitive. Once authenticated, modifying `config.php` gave direct PHP code execution as the apache process user. Application administrators must not be trusted with file-level code execution capabilities without additional controls such as read-only file system permissions or file integrity monitoring.

2.5 SUID Enumeration Should Always Be Performed

The SUID binary identified on OPFOR-02 that called an external command without an absolute path enabled reliable privilege escalation via PATH environment variable manipulation. This technique is well-documented but remains unmitigated on many systems. SUID enumeration with `find / -perm -4000 -type f` should be a standard post-exploitation step.

3. Failed Hypotheses and Abandoned Paths

FTP Anonymous Login

ProFTPD 1.3.3d on Port 21 was the first service investigated. Anonymous login was attempted but rejected. The service required authentication. With no credentials at this stage, FTP was deprioritised in favour of the HTTP attack surface.

Direct File Upload Without Authentication

Unauthenticated file upload to the Apache web root was assessed using dirb-discovered paths. OS-level permissions prevented writing to the web root. This approach was abandoned and the focus shifted to the OpenEMR application endpoint.

Kernel Exploit for Privilege Escalation

Linux kernel 2.6.38 has several known privilege escalation CVEs. However, identifying and reliably compiling a working kernel exploit within the time constraints of the engagement would have been higher risk than the SUID PATH hijacking path, which offered a cleaner, more controlled escalation route with less risk of system instability.

4. Improvements for Future Operations

- Begin FTP investigation in parallel with HTTP — ProFTPD may accept credential reuse from application databases.
- Capture exact timestamp of every phase transition for tighter operator activity log accuracy.

- Test for XSS and other injection vectors in addition to SQLi during initial web enumeration.
- Run LinPEAS/LinEnum earlier in the post-exploitation phase to systematically identify all privilege escalation vectors.
- Use a pre-flight checklist to verify nc listener is running before triggering reverse shell.

5. Student Acknowledgement

Student Full Name	Daniyal Ahmed
Registration Number	C11/26/EHIT/17331
Signature	Daniyal
Date	22 September 2026